- Engineering used ABAC to control access to production deployment tools. Engineers with high clearance and using a company-managed device could deploy during business hours. Outside those hours, they also needed to be on call.
- Finance systems required that only employees in the finance department with the necessary clearance could view sensitive quarterly reports. Even then, they could only see those from their region.
- HR enforced policies that limited access to employee records based on attributes such as data sensitivity, request purpose, and regulatory flags. For example, a policy might permit access to compensation data only when the request is for approved audit purposes and the requester has proper clearance.

Figure 6.4 illustrates a simple example of ABAC in use. Alice and Bob are both in the finance department and work from the same location. However, only Alice has the clearance needed to view the Q2 Financial Data. The policy that enforces this—stored as code—permits access only if the principal's department matches the resource's owner, the clearance level is high, and the access happens before a specified time of day.

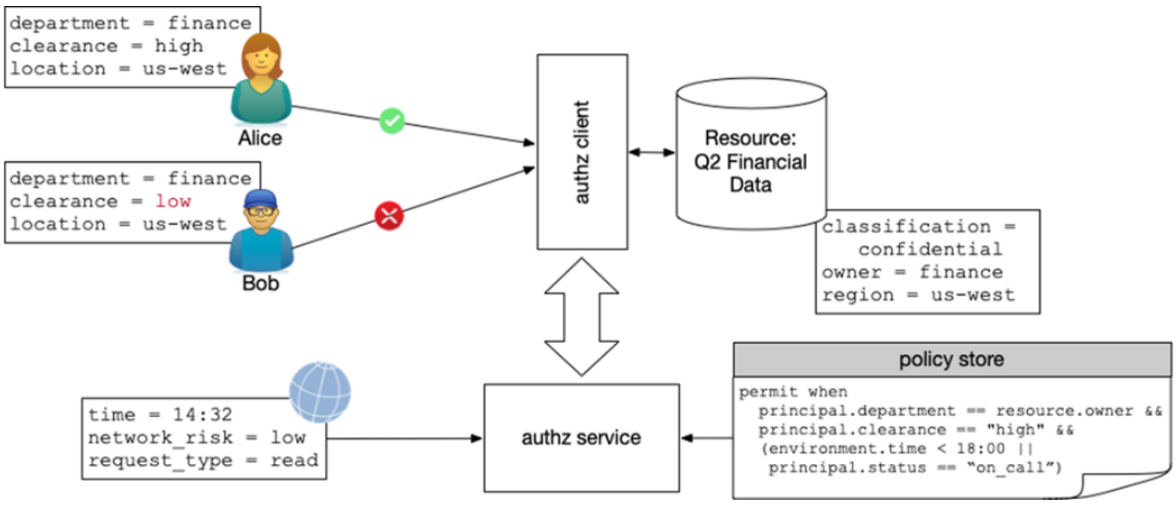


Figure 6.4 Attribute-based authorization with principal, resource, and environment attributes. Access decisions are based on evaluating policies in the context of attributes from multiple sources. Alice's attributes meet the policy conditions, so access is granted. Bob's do not, so access is denied.

ABAC is powerful because it treats authorization as a dynamic decision: given this set of attributes and current conditions, should access be granted?